
Build Solution

Given a use case, create a security solution for inbound or outbound integrations.

Develop your career with Salesforce Training and Certification Preparation

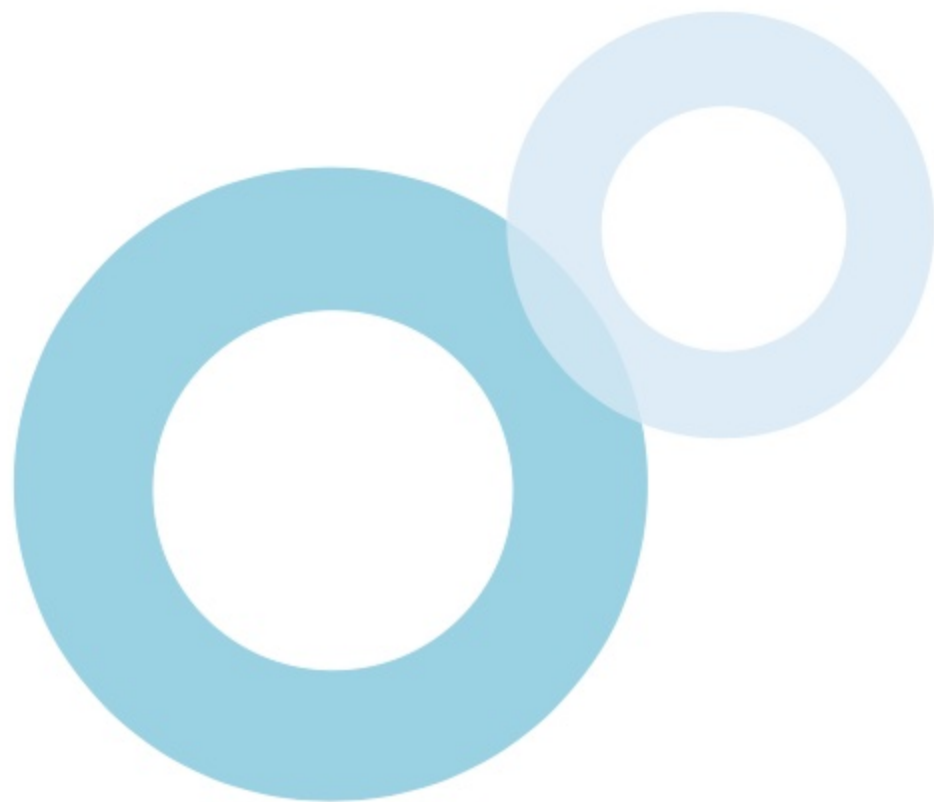
Table of Contents

-  [Inbound Integration](#)
-  [Outbound Integration](#)
-  [Other Security Considerations](#)
-  [Privacy and Security](#)
-  [Use Cases](#)



After studying this topic, you should be able to:

-  Identify the security features and considerations when implementing inbound integrations
-  Identify the security features and considerations when implementing outbound integrations
-  Determine other security features and considerations when building integrations with Salesforce



Introduction

When integrating external applications that perform **inbound requests** to Salesforce, it is critical to be aware of the security implications, considerations, and features in the different layers of the platform architecture. Implementing security features available in the **authentication**, **network**, **session**, and **data** layers helps deliver secure solutions while providing reliable services to external clients.

Salesforce also provides recommendations for securing an integration solution where the org performs **outbound calls** to the external application such as **data encryption**, **2-way SSL**, etc. In this topic, related **features**, **recommendations**, and **considerations** as well as use cases will be covered.



Overview

Authentication Security

Salesforce supports several authentication protocols and features for integrated applications

Network Security

External application access to Salesforce can be restricted based on timing and IP range

Session Security

HTTPS connection are required and other session validation features can be used

Data Security

Access should be restricted using Salesforce data security model

2-Way SSL

Server and client identities can be confirmed first before data transaction

Encryption

Data can be encrypted to secure private information during its transit to the recipient

IP Whitelist

Server can be configured to accept requests only from specific IPs

Proxy Servers

Forward/reverse proxy servers can be used to protect client/server identities respectively

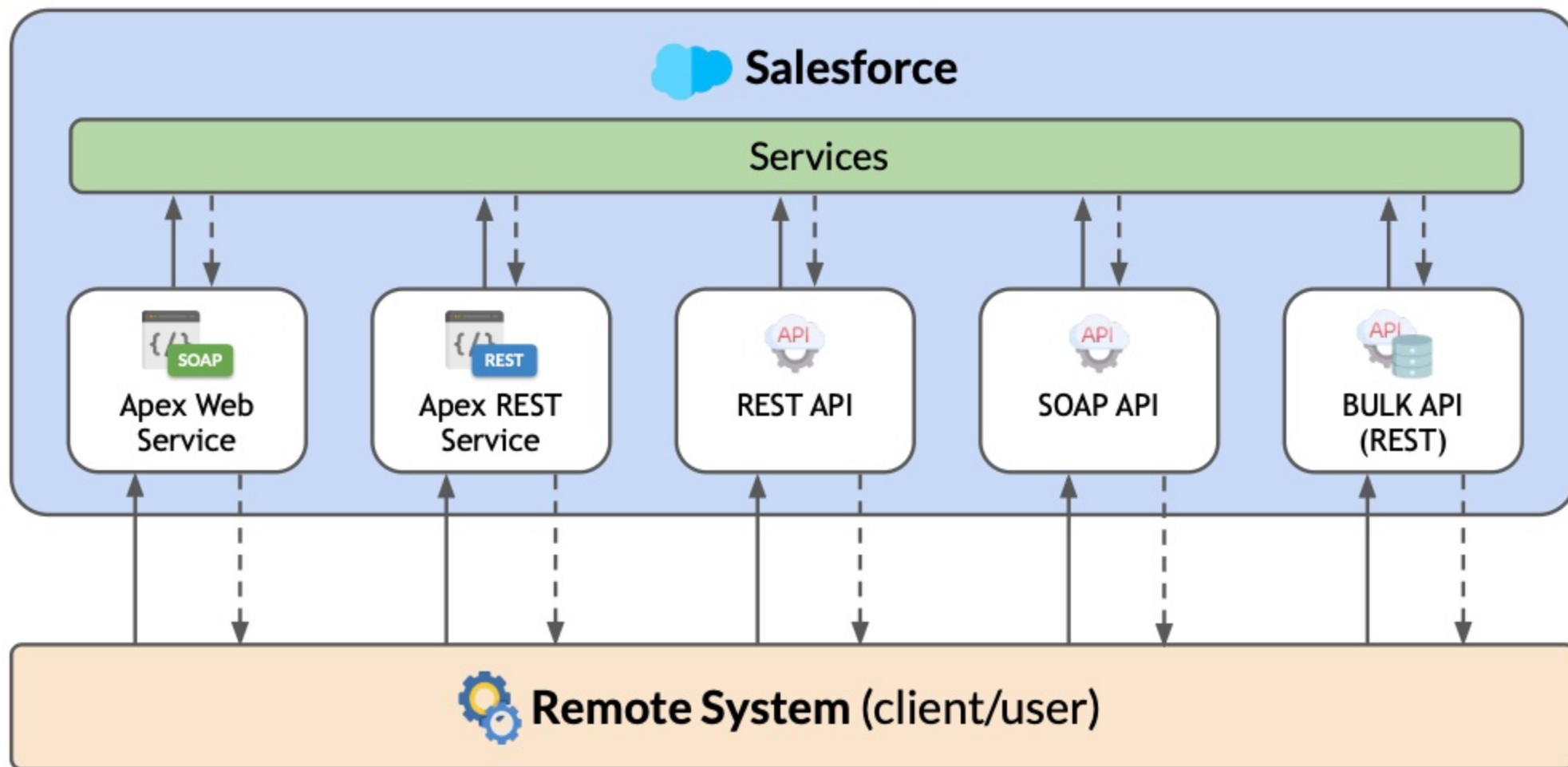


Inbound Integration

[Table of Contents](#) 

Inbound Integration Security

In inbound integration, Salesforce **exposes its services** and accept **inbound requests** from a remote system. Salesforce provides several **security features** for protecting the platform.



Inbound Integration Client

An inbound integration client accesses the Salesforce platform as an **integration user**. Some recommendations and features to **secure and validate access** are described below.

❖ AUTHENTICATION SECURITY

- A **security token**, which is reset whenever a password is reset, is required when username & password is used to login via API.
- A **Connected App** can be used to integrate applications with Salesforce using standard protocols such as **OAuth**, **SAML** (Security Assertion Markup Language), and **OpenID Connect**.
- **Multi-factor authentication** is available (e.g. verification via email or phone, time-based token) for additional login security.
- A **Lightning Platform license** can be used by the integration user.



Inbound Integration Client

An inbound integration client accesses the Salesforce platform as an **integration user**. Some recommendations and features to **secure and validate access** are described below.

❖ AUTHENTICATION SECURITY (CONT'D.)

- The user is required to interact with Salesforce via API only (Enable **API Only User**).
- The **Salesforce Integration user license** can be used for integration users that should access Salesforce resources **only through an API**.
- To provide the **minimum required access** to API users, the **Minimum Access - API Only Integrations** user profile should be used with the Salesforce Integration user.



Inbound Integration Client

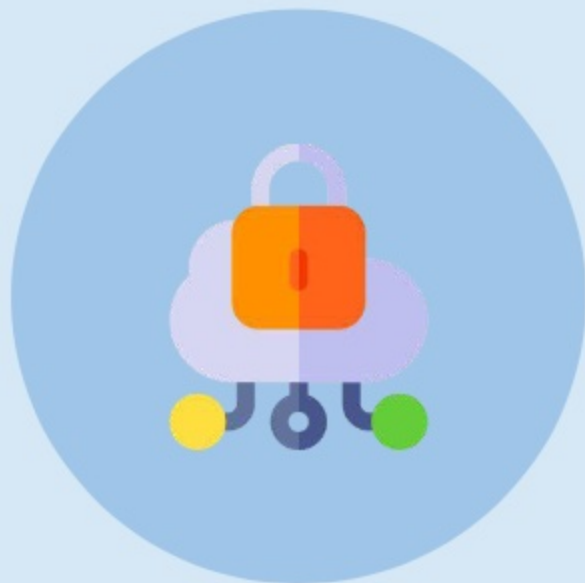
An inbound integration client accesses the Salesforce platform as an **integration user**. Some recommendations and features to **secure and validate access** are described below.

❖ NETWORK SECURITY

- The user can be restricted from **logging in** outside specific **hours**.
- The user can be required to **access** the org from a specific **IP range**.

❖ SESSION SECURITY

- A **secure connection** (HTTPS) is enforced in the communication.
- A **login IP range** validation can be activated for every request.
- The user can be automatically logged out on **session timeout**.
- **Clickjack** and **cross-site request forgery** (CSRF) protection is enabled.



Inbound Integration Client

An inbound integration client accesses the Salesforce platform as an **integration user**. Some recommendations and features to **secure and validate access** are described below.

❖ DATA SECURITY

Security settings such as **profile**, **permission sets**, and **sharing rules** should be configured accordingly to ensure that integrated external applications can only:

- Perform actions on the objects it is allowed to (**object-level security**).
- Access the records it is allowed to (**record-level security**).
- View the fields of a record it is allowed to (**field-level security**).

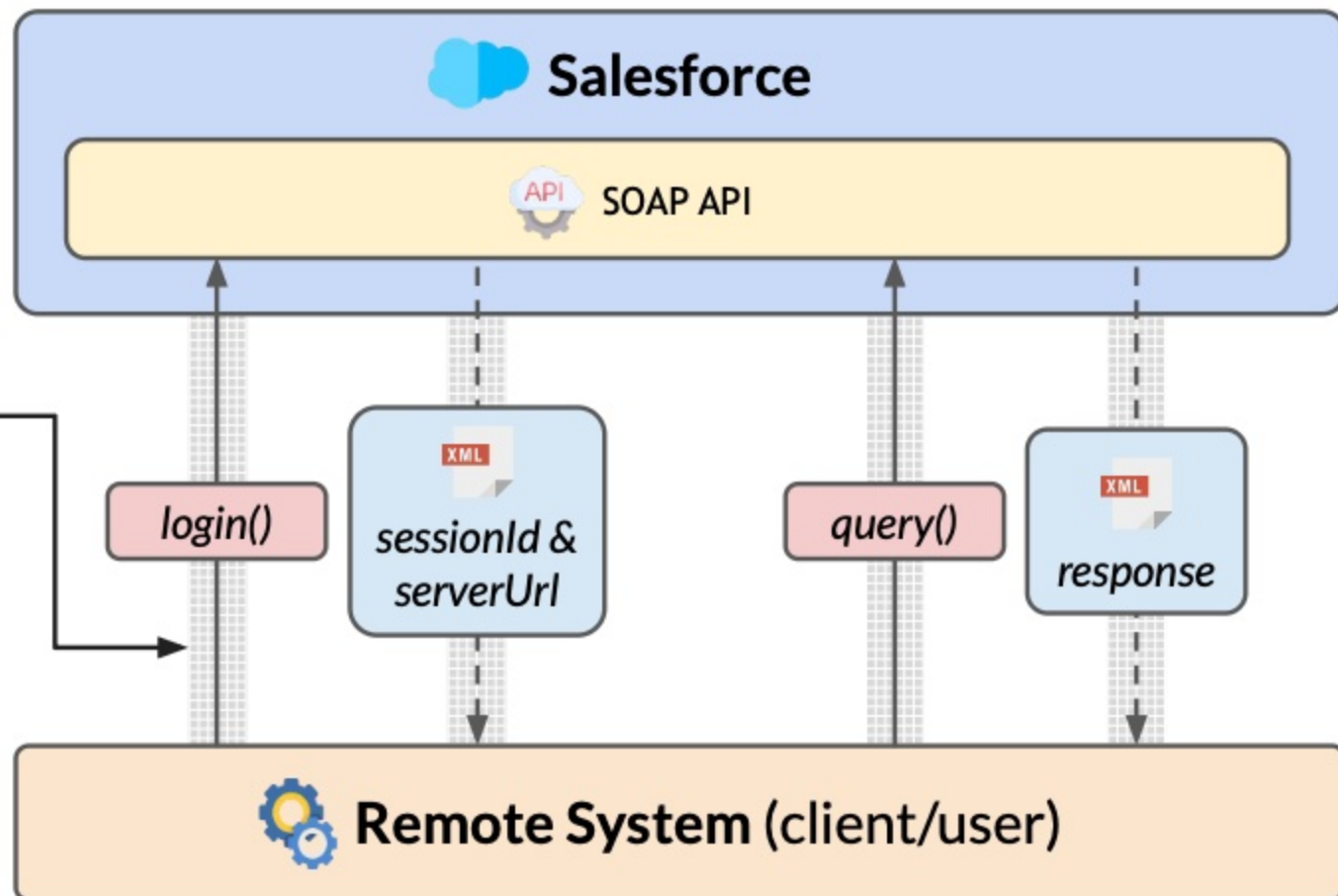


SOAP API

When a remote client uses SOAP API to communicate with Salesforce, it is required to **obtain a session** first in order to **perform any API call**.

Communication can be secured using **Secure Sockets Layer** or **Transport Layer Security**. Algorithms, called **ciphers**, used for encrypting and decrypting data must have a key length of at least **128 bits**.

Note: The SOAP API login will be **retired** in **Summer '27**.

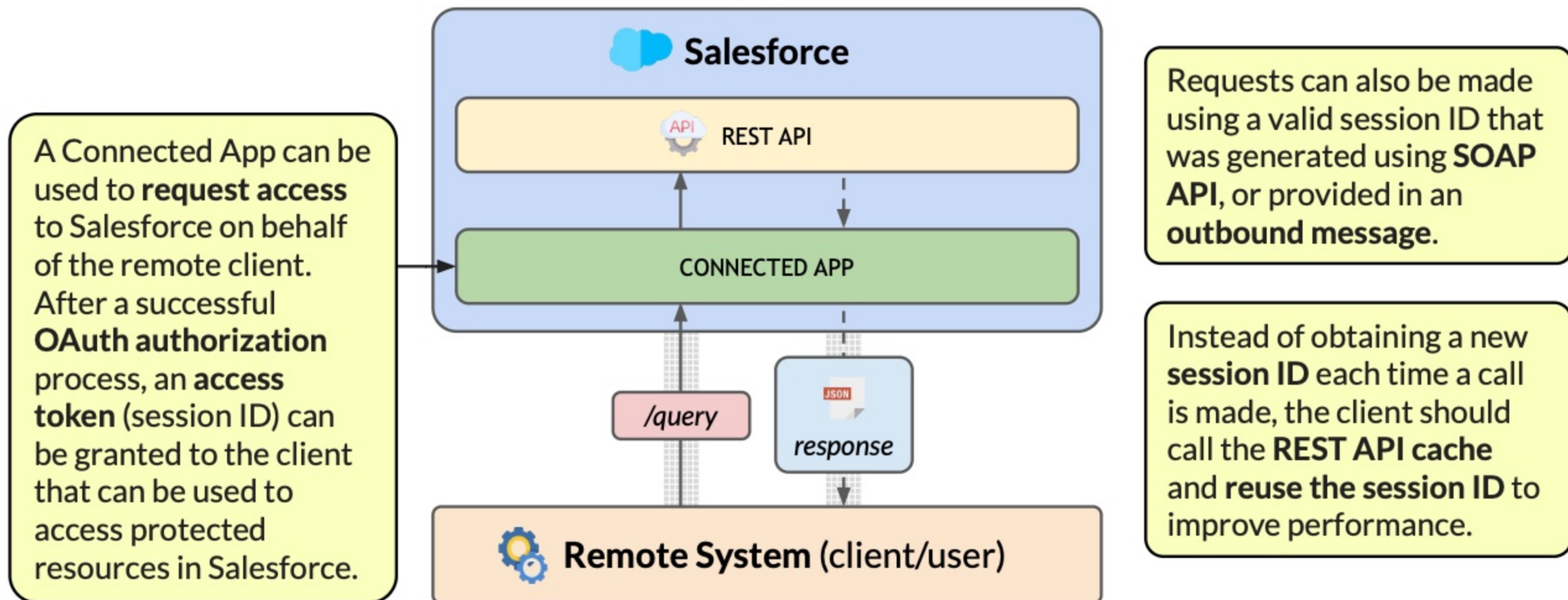


When the login of the remote client has been successfully validated, Salesforce provides a **sessionId** and **serverUrl** that the client can use for subsequent calls.

Instead of obtaining a new **session ID** each time a call is made, the client should call the **SOAP API cache** and **reuse the session ID** to improve performance.

REST API

To communicate with Salesforce via REST API, Salesforce requires using **OAuth** for the authorization. In this case, a **Connected App** can be used to authenticate the remote client.



Other Integration Solutions

When using the integration solutions below to perform **inbound calls**, Salesforce recommends using an **OAuth process** for authorizing the remote client.



APEX WEB SERVICES

Create a custom SOAP API by exposing Apex class methods as web service methods.



APEX REST SERVICES

Create a custom REST API by exposing an Apex class as REST resources.



BULK API

Use Bulk API 2.0 to perform data operation that involves more than 2,000 records.

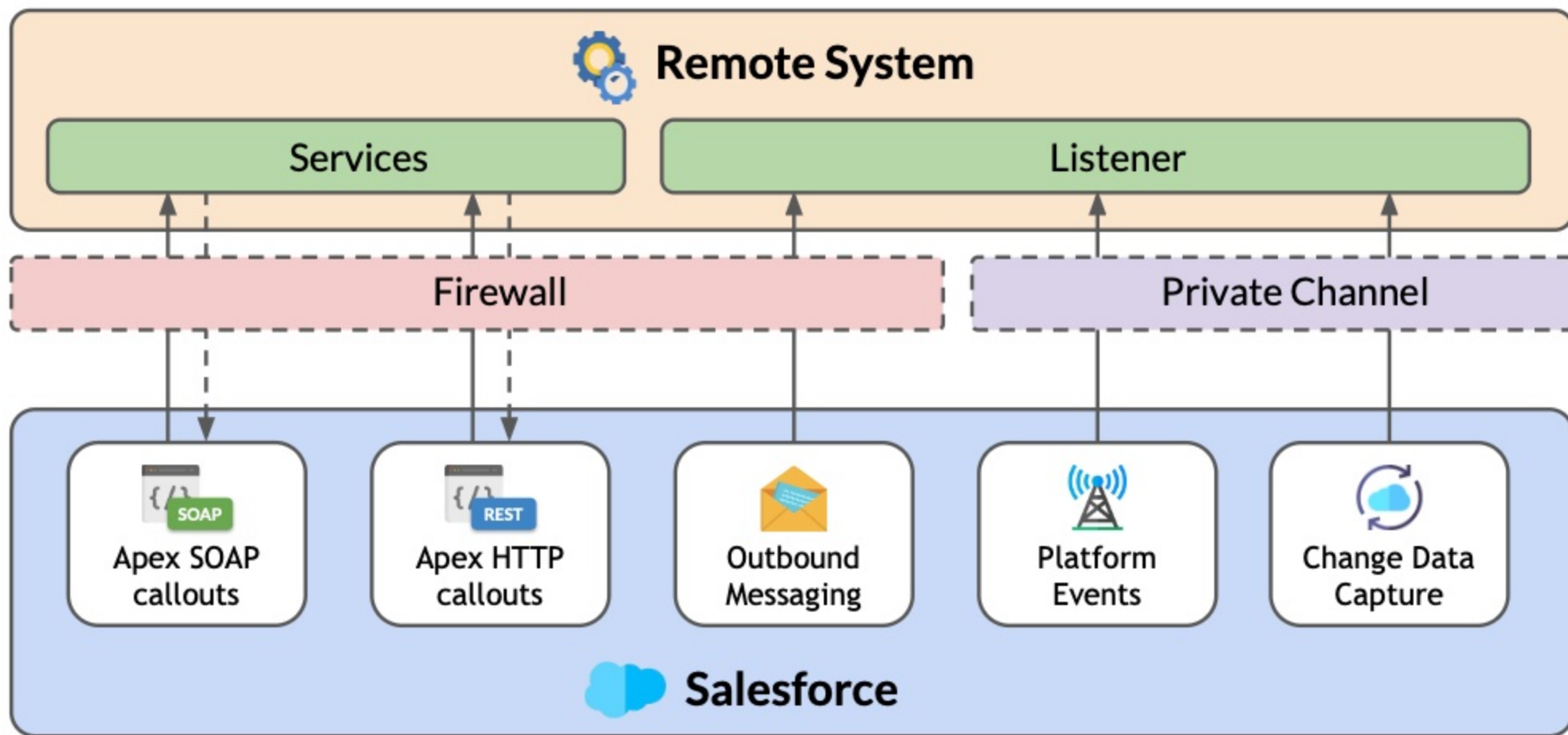
Outbound Integration

Table of Contents



Outbound Integration Security

In outbound integration, Salesforce may **perform a callout**, **consume a service**, or **send a message** to the remote system. Security measures can be implemented based on the solution used.



Apex SOAP and HTTP Callouts

The following describes **security recommendations** when using Apex SOAP and HTTP callouts in a **remote process invocation** integration pattern.

❖ TWO-WAY SSL

Security Sockets Layer (SSL) is an encryption protocol used to secure a communication channel between two systems. In **one-way SSL** (enabled by default), only the client validates the identity of the server prior to actual data requests. Salesforce also supports **two-way** (mutual) **SSL** where both the server and client is required to validate each other's identity using self-signed and CA-signed (Certificate Authority) certificates.

❖ FIREWALL

The **remote system** should implement a firewall to prevent **unauthorized access**, identify and block **threats**, and monitor **network traffic**.



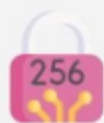
Apex SOAP and HTTP Callouts

The following describes **security recommendations** when using Apex SOAP and HTTP callouts in a **remote process invocation** integration pattern.



APEX CRYPTO

Data encryption can be used to ensure that data has not been tampered with. To preserve the **integrity** of a message, **one-way hashes** or **digital signatures** can be generated using the **Apex Crypto** class.



ONE-WAY HASH

The **Crypto.generateDigest()** method can be used to generate a one-way hash digest using **MD5**, **SHA1**, **SH256**, or **SHA512** (most secure). The integrity of the message can be validated in the server/receiver by ensuring that an **identical hash** is generated using the same encryption algorithm.



DIGITAL SIGNATURE

The **Crypto.sign()** method can be used to generate a **unique signature** for the message using the sender's **private key** and specified **signing algorithm**. This is used to digitally sign and validate the **authenticity** of the message and as a **proof** that the sender did send the message.

Outbound Messaging

The following describes **security recommendations** when using outbound messaging in a **remote process invocation** integration pattern.

❖ TWO-WAY SSL

Validation can be implemented using **one-way SSL** (default) or **two-way SSL** before an outbound message is sent to the remote system.

❖ FIREWALL

The **remote system** should implement a firewall to prevent **unauthorized access**, identify and block **threats**, and monitor **network traffic**.

❖ WHITELIST IP

Salesforce server IP ranges should be whitelisted in the remote server and/or firewall.



Platform Events

The following describes **security considerations** when using platform events in a **remote process invocation** integration pattern.

❖ STREAMING API

The remote system should be able to **authenticate itself** to the Salesforce Streaming API.

❖ OBJECT ACCESS

In order to **subscribe** to a platform event, the receiver should be permitted **read access** to the Platform Event object.



Change Data Capture

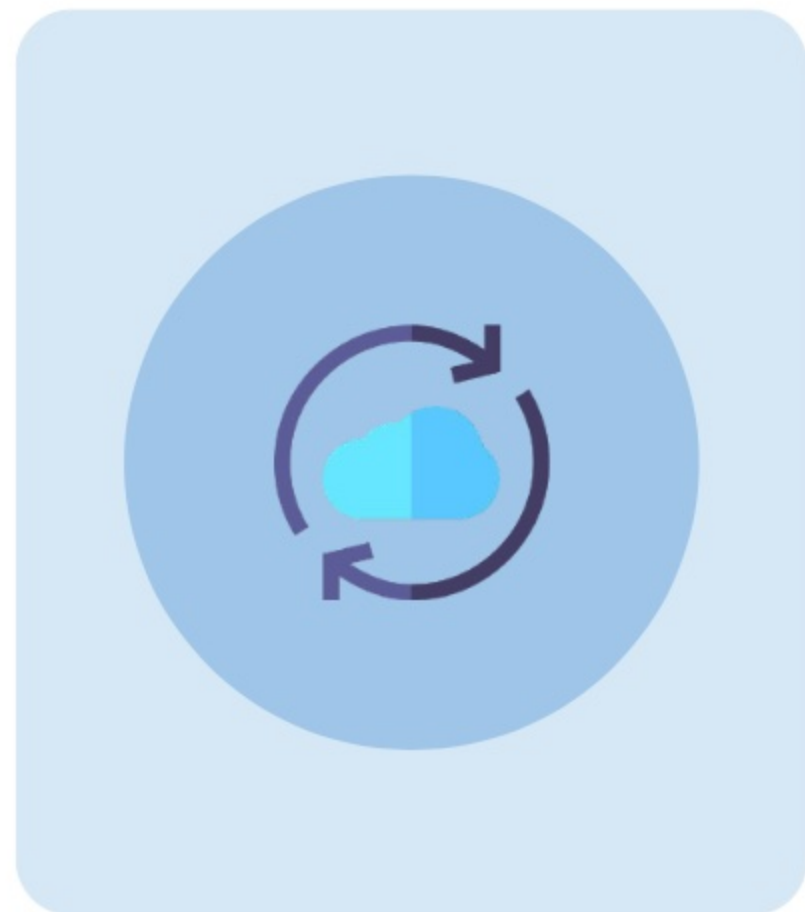
The following describes **security considerations** when using Change Data Capture in a **remote process invocation** integration pattern.

❖ RECORD VISIBILITY

Change Data Capture **ignores sharing settings** such that it sends change events **for all records** of a specified object to subscribers.

❖ FIELD VISIBILITY

Change Data Capture respects **field-level security settings**. If a subscribed user does not have access to a field, for example, in an object for a change event, it is **automatically removed** from the event message before it is delivered.



Change Data Capture

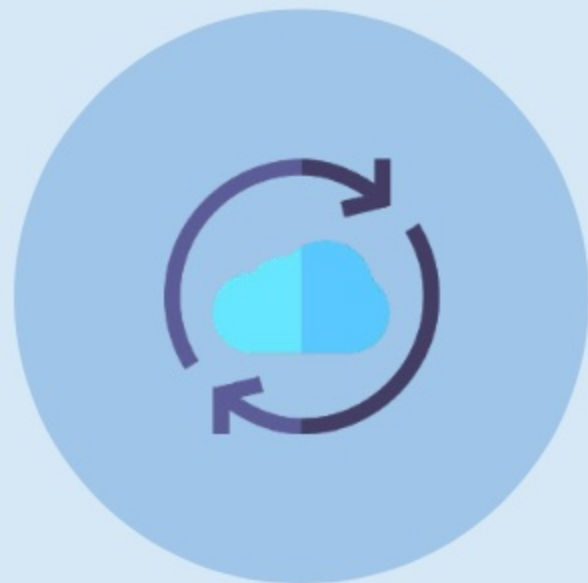
The following describes **security considerations** when using Change Data Capture in a **remote process invocation** integration pattern.

❖ ENCRYPTED DATA

Fields encrypted with **Shield Platform Encryption** generate change events when their values are changed. Change events are stored in the event bus for up to **three days**. So to ensure that data is secured, encryption should be enforced by creating what is called an **event bus tenant secret** from the **Key Management** page in the Salesforce Setup page and then enabling encryption in the **Encryption Policy** page.

❖ EVENT PAYLOAD

When encryption is enabled, the event payload is encrypted using the **data encryption key** that is based on the event bus tenant **secret type**.



Other Security Considerations

[Table of Contents](#)



Legacy Named Credentials

The legacy named credential stores the **URL** and **authentication parameters** of a callout endpoint.

❖ SIMPLE AUTHENTICATION

Named credentials are recommended for simple authentication schemas such as **username-password** authentication, or **OAuth 2.0**.

❖ PRIVATE CONNECTION

The **OutboundNetworkConnection** field available in a named credential can be used to route callouts through a private connection.

❖ SECURITY AND CONVENIENCE

Hardcoding usernames, passwords, API keys, and other secrets in Apex code can be avoided. If an **API key** or **endpoint URL**, for example, changes, only the named credential needs to be updated.

Only **administrators** and users with **View/Modify All Data** permissions can access configuration data in a named credential.

Note that **legacy named credentials will be deprecated** in a future release. Salesforce recommends using the **improved named credentials** made available in the Winter '23 release.

Improved Named Credentials

Salesforce introduced the new generation of named credentials in Winter '23. In this version, the **authentication parameters** are stored separately in a related component called **External Credentials**.

❖ CREATING NAMED CREDENTIALS

In addition to Salesforce Setup, **Named** and **External Credentials** can be created through **Connect API** from within Connect API, including applications written in Apex.

❖ AUTHENTICATION PROTOCOLS

The supported authentication protocols in an external credential are **OAuth**, **AWS Signature Version 4**, **JWT**, **Custom**, and **No Authentication**.

❖ USER EXTERNAL CREDENTIALS

Unlike **standard** permission sets and profiles, **custom** permission sets and profiles need to be granted access to the **User External Credentials object** to allow its users to perform authenticated callouts using the name credential.



Improved Named Credentials

Salesforce introduced the new generation of named credentials in Winter '23. In this version, the **authentication parameters** are stored separately in a related component called **External Credentials**.

❖ OTHER CHARACTERISTICS

An external credential can be related and referenced by multiple **named credentials** as well as **permission sets**. External credentials support creation of **custom headers**. External credential principals can be linked to **OAuth scopes** for more granular access control.



Managed Packages

To distribute **secrets** such as passwords, API keys, code, etc. across multiple orgs, for example, that even **system administrators** are **incapable of accessing**, managed packages can be used.

❖ MANAGED PACKAGE BENEFITS

- **Updates, patches, fixes** can be **automatically pushed** without requiring the subscriber org to reinstall a new version of the package.
- Code is **obfuscated** (unless explicitly exposed) to secure and protect fundamental business logic as well as **hide** secrets in the package.
- Package secrets **cannot be accessed by code** that runs outside the managed package's namespace, which is unique..
- The use of managed packages grants access to the following features: **protected custom settings** and **protected custom metadata**.



Custom Settings

Custom settings in Salesforce efficiently **store** data, **enhance** performance, and **securely manage** sensitive information.



PURPOSE

Custom settings store flexible data sets exposed to the application cache, reducing database queries and improving app efficiency.



USE CASES

They can personalize user experiences, provide quick access to frequently referenced data, or store sensitive information securely.



VISIBILITY

Custom settings can be protected (in managed packages, hidden from subscribers) or public (visible via the Enterprise WSDL).



SECURITY

Sensitive data should be stored in protected custom settings within managed packages to ensure security.

Custom Metadata

Custom metadata types securely store **sensitive data**, like API keys, by using **protected visibility** within managed packages.



SECRET STORAGE

Custom metadata fields can store sensitive data, such as API keys, by setting visibility to Protected and placing them in a managed package.



VISIBILITY OPTION

Custom metadata fields (and custom settings) have the visibility options: Public (local), Protected (local), Public (managed), and Protected (managed).



SECURITY

While the other visibility options allow public access to the data, the Protected (managed) option restricts public access and ensures data security.



ADVANTAGE

Custom metadata fields offer obscured visibility, ease of access, and caching, making them an efficient choice for secret storage.

Custom Settings or Custom Metadata

Although both protected custom settings and protected custom metadata types can **secure secrets**, they have notable differences and as to when to use one over the other.



USE CUSTOM SETTINGS

For **frequently updated secrets** needing immediate availability, custom settings are better than metadata types, which require deployment.

Custom settings are better for specifying **profile- or user-level access** to secrets, as metadata types lack this granularity.



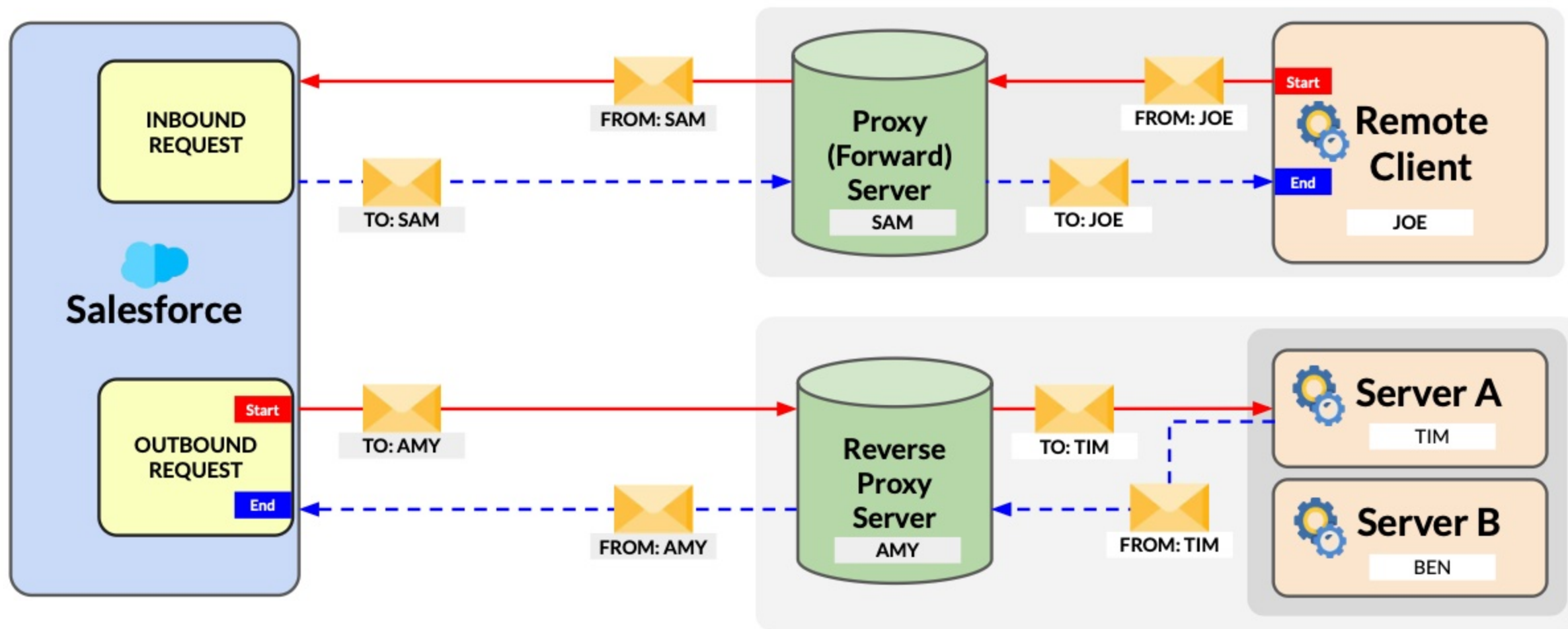
USE CUSTOM METADATA TYPES

When deploying a **common secret** that requires no extra configuration steps, custom metadata types are used.

Custom metadata secrets are **easily migratable between environments**, while custom settings require **post-install scripts** or **manual entry** by admins.

Forward/Reverse Proxy Server

Forward and reverse proxy servers can be used to improve **security**, **performance**, and **reliability**. While a **forward** proxy hides **client** identity, a **reverse** proxy hides **server** identity.



Encryption

The following describes alternative **on-premises** and **cloud-based applications** used for encrypting transactions or data fields.

❖ ON-PREMISES OPTIONS

When using on-premises commercial encryption gateway services, the encryption engine or gateway is invoked by **sending & receiving** an encrypted payload, or **encrypting/decrypting data** before executing a callout. Salesforce, CipherCloud, IBM DataPower, or Computer Associates, for example, provides these services commercially.

❖ CLOUD-BASED OPTION

Salesforce Shield Platform Encryption can be used to encrypt data at rest, or when stored in Salesforce servers, using an **advanced key derivation system**. To secure data in transit or during transactions, Apex Crypto, for example, can be used.



WS-Security Support

Apex callouts do not support **WS-Security**, which is an industry-standard security protocol used to enhance web service protection from attacks. The following describes the alternative options.

❖ SECURITY/XML GATEWAY

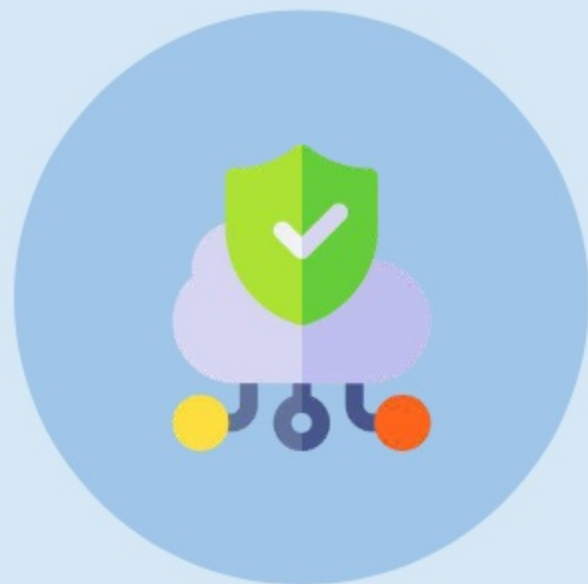
WS-Security credentials are injected into the transaction stream using a commercial product (IBM WebSeal or Datapower, Layer7, TIBCO, etc.).

❖ TRANSPORT-LEVEL ENCRYPTION

Communication is encrypted using **2-way SSL and IP restrictions** to secure the communication channel between on-premises **applications** and **Salesforce** without passing a username and password.

❖ CUSTOM DEVELOPMENT

WS-Security headers are added to **outbound SOAP requests** via the **WSDL2Apex utility**, but is **not recommended** due to its complexity and risk.



Private Connect

Private Connect is a feature that allows secure inbound and outbound communication with **Amazon Web Services** (AWS).



- ❖ It allows sending and receiving HTTP/s traffic securely between Salesforce and **AWS Virtual Private Cloud** (VPC).
- ❖ The data between the Salesforce org and the VPC is routed through a feature called **AWS PrivateLink**.
- ❖ Since Private Connect is bi-directional, it secures both **inbound and outbound** integrations.
- ❖ **Standard APIs** can be used to send data from VPC to Salesforce.
- ❖ Features like Apex callouts, External Objects, and External Services can be utilized to **send data** from Salesforce to VPC.

Privacy and Security

Table of Contents



Privacy and Security

Stored data can be encrypted to prevent **unauthorized access** or, at the very least, its **readability**. Tools use different **authentication protocols** and may or may not be used with the encrypted data.

Inbound Integration (External System -> Salesforce)		
Integration Tool	Authentication Protocol Used	Supports Data Encrypted at Rest
Salesforce Connect (OData 2.0/4.0/4.01 Adapters)	Multiple protocols supported	❌ (External Object fields cannot be encrypted.)
Salesforce Connect (Custom Apex Adapters)	Multiple protocols supported	❌ (External Object fields cannot be encrypted.)
Platform Events	OAuth	✅
Apex REST/SOAP Web Services	Multiple protocols supported	✅
Salesforce Standard APIs	Multiple protocols supported	✅

Privacy and Security

Outbound Integration (Salesforce -> External System)		
Integration Tool	Authentication Protocol Used	Supports Data Encrypted at Rest
Change Data Capture	OAuth	✓
External Services	Named Credentials	✗
Salesforce Connect (OData 2.0/4.0/4.01 Adapters)	Named Credentials	✗ (External Object fields cannot be encrypted)
Salesforce Connect (Custom Apex Adapters)	Multiple protocols supported	✗ (External Object fields cannot be encrypted)
Apex Actions	Multiple protocols supported	✓
Generic Events	OAuth	✗
Outbound Messages	Two-way TLS	✓
Platform Events	OAuth	✓
PushTopic	OAuth	✗
Custom Apex	Multiple protocols supported	✓

Use Cases

Table of Contents 

Scenario 1



SCENARIO

An events management company needs to be able to retrieve specific Account and Contact **records** regularly from the Salesforce org of their partner sales company for their internal operations. Salesforce developers of the sales company has built a **custom REST API** that can be used to provide the records to the events company as a service. One of the IT security policies of the events company is that any integration with external systems, including Salesforce, should be authenticated using the **OAuth 2.0** authorization protocol.



Solution 1



SOLUTION

When building a solution that requests data access in Salesforce as a **REST API** consumer, Salesforce requires using the **OAuth** protocol as the authentication standard in the integration. In this case, a **Connected App** can be used to authorize and request access to Salesforce on behalf of the remote client. Connected App is an **integration framework** in Salesforce that supports several standard protocols for authentication and authorization such as SAML, OAuth, and OpenID Connect.



Scenario 2



SCENARIO

A vocational institution uses Salesforce to manage **courses**, **tutors**, and **class schedules**. A web application operated by a third-party reseller uses **SOAP API** to collect data from Salesforce to display the information on their portal where users can browse for course and class availability and potentially enroll. The Salesforce administrator of the vocational institution has been delegated to ensure that proper **security measures** are in place to prevent the reseller from accessing or collecting information from Salesforce that is not related to the requirement.



Solution 2



SOLUTION

In an integration solution where Salesforce is the master, the remote system accesses the org as an **integration user** and is subject to Salesforce's comprehensive **security model** that controls what data can be accessed, operations that can be performed, features that can be used, and restrictions that are being imposed. So, in addition to implementing an effective **sharing model**, the **profile and/or permission sets** related to the integration user should be configured accordingly to secure org data and integrity. Security features such as **login-hour & IP-address restrictions**, **per-request session validation**, and other settings should be enforced for an even tighter security.



Scenario 3



SCENARIO

A logistics company needs to consume a **SOAP web service** from an external platform that would enable them to manage and track global shipments within their Salesforce org. The company's Salesforce developers then created Apex controllers based on the **Apex proxy class** that was generated from a **WSDL file** required by the web service provider. It was later determined that Apex callouts do not support **WS-Security** and poses a **security risk**. In its current state, the developed solution fails to meet the company's IT security policy. The company's VP of technology has sought a recommended solution in order to move the project forward.



Solution 3



SOLUTION

As **Apex callouts** do not support WS-Security, Salesforce provides a few alternatives as a solution or workaround for the current limitation. One of the recommended options is to use a **Security/XML gateway**. By implementing a commercially available security/XML gateway gateway such as **IBM WebSeal** or **Datapower**, **Layer7**, **TIBCO**, and others, WS-Security credentials **can be injected** in the web service communication. Another option is to secure the transport layer by **encrypting** the communication channel using **two-way SSL** and **IP address** restrictions.



Learn More

-  [Protect Secrets Using Platform Features](#)
-  [Named Credentials as Callout Endpoints](#)
-  [Security Considerations](#)
-  [Change Data Capture Security Considerations](#)
-  [Enable OAuth Settings for API Integration](#)
-  [Encryption and Signature Techniques in Apex](#)
-  [How Shield Platform Encryption Works](#)
-  [Salesforce Security Guide](#)